Повышение квалификации специалистов по информационной безопасности

КОНСПЕКТ ЛЕКЦИИ 2

по курсу
«Мониторинг компьютерных атак»

АРХИТЕКТУРА МОНИТОРИНГА И РЕАГИРОВАНИЯ

Роли, уровни мониторинга, качество сигналов, ложные срабатывания

(2 академических часа)

2026

СОДЕРЖАНИЕ

Введение 4

1 Роли и процессы центра мониторинга 6

1.1 Функции центра мониторинга 6

1.2 Роли и уровни 6

1.3 Процесс обработки сигнала 7

1.4 Показатели работы центра 7

2 Архитектура системы мониторинга 9

2.1 Уровни мониторинга 9

2.2 Компоненты и поток данных 9

2.3 Пример реализации на Elastic Stack 10

2.4 Нормализация и обогащение 11

2.5 Данные об угрозах 12

3 Правила обнаружения 13

3.1 Язык правил Sigma 13

3.2 Окна времени 16

3.3 Алгоритм создания правила 17

3.4 Сложение слабых сигналов 17

4 Качество сигналов и ложные срабатывания 18

4.1 Ошибки обнаружения 18

4.2 Перегрузка аналитика потоком сигналов 18

4.3 Способы снижения ложных срабатываний 19

4.4 Обнаружение как код 19

5 Реагирование и его автоматизация 20

5.1 Жизненный цикл реагирования 20

5.2 Автоматизация реагирования 20

Заключение 21

Список использованных источников 22

Приложение А Вопросы для самопроверки 24

ВВЕДЕНИЕ

Сл. 1

Лекция посвящена тому, как устроена система мониторинга компьютерных атак и кто в ней что делает: от сбора событий до реагирования на инцидент. Материал построен вокруг одной сквозной ситуации, которая проходит через все главы.

Сл. 2

Система мониторинга существует для того, чтобы из огромного числа событий отобрать небольшое число сигналов, а из сигналов подтвердить инциденты и вовремя на них отреагировать. Последовательность изложения (таблица 1): сначала люди и процессы, затем технические компоненты, затем правила обнаружения, затем показатели качества сигналов и, наконец, реагирование.

Таблица 1 — Последовательность изложения

Глава	Вопрос	Результат
1	Кто и по какому порядку разбирает сигналы?	Роли, уровни и процесс обработки сигнала
2	Откуда и как поступают данные?	Уровни мониторинга и архитектура
3	Как описать атаку правилом?	Правила обнаружения и корреляция
4	Насколько можно доверять сигналам?	Точность, полнота, снижение ложных срабатываний
5	Что делать после подтверждения?	Реагирование и его автоматизация

Сл. 3, 4

Рассмотрим сквозную ситуацию. Нарушитель подбирает пароль учётной записи *anna* веб-приложения: с адреса 203.0.113.7 за две минуты поступает пять неудачных попыток входа, а затем вход завершается успехом. Для описания того, что происходит дальше, нужны три понятия, различие между которыми лежит в основе всего мониторинга (таблица 2). Согласно глоссарию NIST, **событием** называется любое наблюдаемое явление в сети или информационной системе [1]. **Сигналом** (в англоязычной терминологии — alert) называется уведомление о том, что на информационные системы организации направлена конкретная атака [2]. **Инцидентом** называется происшествие, которое фактически или неминуемо ставит под угрозу без законных полномочий конфиденциальность, целостность или доступность информации либо информационной системы, а также нарушение или неминуемая угроза нарушения законов, политик и процедур безопасности [3].

Таблица 2 — От события к инциденту

Понятие	**Что это в нашей ситуации**	**Кто с ним работает**
Событие	Запись о неудачном входе: время, адрес, учётная запись, результат	Никто напрямую: событий десятки тысяч
Сигнал	«Пять неудач за 10 минут, затем успешный вход» — сработало правило обнаружения	Аналитик первой линии
Инцидент	Учётная запись *anna* вероятно захвачена нарушителем	Группа реагирования

1 Роли и процессы центра мониторинга

1.1 Функции центра мониторинга

Сл. 6

Организационной единицей, которая ведёт мониторинг и реагирование, служит центр мониторинга и реагирования (в англоязычной практике — Security Operations Center, SOC). Это может быть отдельное подразделение, группа специалистов или функция, выполняемая по расписанию. Независимо от размера центр выполняет пять функций (таблица 3), соответствующих основным действиям международного руководства по реагированию на инциденты [4].

Таблица 3 — Функции центра мониторинга

Функция	Содержание	Результат
Мониторинг	Сбор и просмотр событий и сигналов	Видимость происходящего
Обнаружение	Правила и методы, которые выделяют подозрительное	Сигналы
Анализ	Разбор сигнала, подтверждение или отклонение	Решение: инцидент или ложное срабатывание
Реагирование	Локализация, устранение, восстановление	Прекращение атаки
Улучшение	Выводы из случившегося, настройка правил	Лучшие правила и процессы

1.2 Роли и уровни

Сл. 7

Чтобы загрузка распределялась разумно, аналитиков делят по уровням ответственности (таблица 4). Простая задача решается быстро на первой линии, сложная переходит выше с накопленным контекстом.

Таблица 4 — Уровни аналитиков

Уровень	Роль	Задачи
1	Аналитик первой линии	Разбор поступающих сигналов: подтвердить, отклонить, передать выше; первичное обогащение
2	Аналитик расследования	Глубокий анализ, корреляция событий, локализация и устранение
3	Инженер по обнаружению и охотник за угрозами	Разработка и настройка правил, активный поиск угроз, не вызванных сигналами

Кроме аналитиков в крупных организациях выделяют координатора инцидента, который управляет действиями при тяжёлых инцидентах, и

аналитика по киберугрозам, который поставляет сведения о нарушителях и их приёмах. Иногда применяется и бесуровневая модель, в которой аналитик ведёт инцидент от начала до конца: она требует более высокой квалификации, но не теряет контекст при передаче.

В сквозной ситуации аналитик первой линии получает сигнал о подборе пароля, подтверждает успешный вход после серии неудач и передаёт случай на второй уровень; тот выясняет, что нарушитель делал под учётной записью *anna* после входа.

1.3 Процесс обработки сигнала

Сл. 8

Обработка любого сигнала идёт по одной схеме (рисунок 1): аналитик первой линии принимает решение одного из трёх видов. Если угроза подтверждена, случай передаётся на расследование. Если это ложное срабатывание, фиксируется причина и правило настраивается. Если данных недостаточно, сигнал обогащается и разбирается повторно.

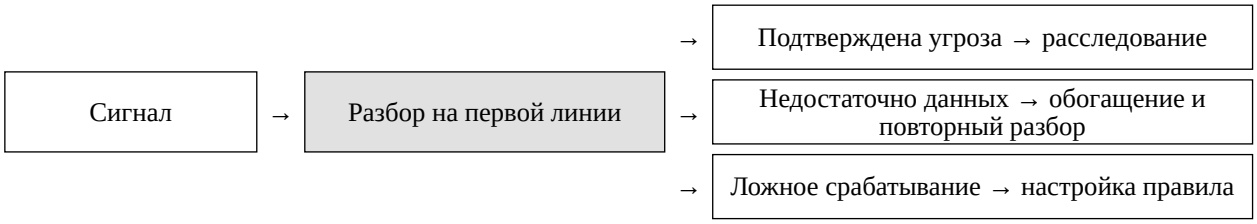


Рисунок 1 — Решения при разборе сигнала

Сл. 9

Для типовых сигналов заранее составляют регламенты разбора (в англоязычной практике — runbook): перечень проверок, данных для сбора и критериев решения. Например, регламент для сигнала о подборе пароля содержит такие шаги: определить, внутренний или внешний адрес источника; сколько было неудач; какая учётная запись атакована (служебная, администратор, обычная); был ли успешный вход после неудач; если да — немедленно передать на второй уровень.

1.4 Показатели работы центра

Сл. 10

Качество работы центра оценивают количественно (таблица 5). Целевые значения каждая организация задаёт сама, исходя из численности аналитиков и требований бизнеса, поэтому в таблице указано, как читать показатель, а не универсальная норма.

Таблица 5 — Показатели работы центра мониторинга

Показатель	Что измеряет	Как читать
Сигналов на аналитика за смену	Нагрузка	Рост без роста штата означает пропуск сигналов
Доля сигналов, переданных выше	Нужда в глубоком анализе	Слишком мала — первая линия не справляется; слишком велика — правила шумят
Среднее время до начала разбора	Скорость реакции центра	Растёт при перегрузке
Время от начала атаки до обнаружения	Видимость	Главный показатель качества обнаружения
Время от обнаружения до устранения	Скорость реагирования	Показывает зрелость процесса

2 Архитектура системы мониторинга

2.1 Уровни мониторинга

Сл. 12, 13

Нарушитель оставляет следы в разных местах, поэтому мониторинг ведут на нескольких уровнях одновременно (таблица 6). Ни один уровень не показывает всей картины: например, сетевой не видит содержимого шифрованного обмена, а хостовый не видит соседние узлы.

Таблица 6 — Уровни мониторинга

Уровень	Источники данных	Что видно	Что не видно
Сетевой	Межсетевой экран, датчики трафика, DNS, прокси	Сканирование, связь с внешними адресами, вывод данных	Содержимое шифрованного обмена
Узла	Журналы операционной системы, запуск процессов, средства защиты конечных точек	Выполнение программ, закрепление в системе	Действия на других узлах
Приложения	Журналы веб-приложения, базы данных	Вход пользователей, обращения к данным, отказы в доступе	Атаки, не дошедшие до приложения
Учётных записей	Каталог пользователей, журналы аутентификации	Входы, смена прав, второй фактор	Что происходит после входа
Облака	Журналы облачного провайдера	Создание ресурсов, изменение политик доступа	Внутренности управляемых служб

В сквозной ситуации подбор пароля виден на уровне приложения (неудачные входы) и учётных записей (последующий вход), а адрес нарушителя можно сверить на сетевом уровне с данными прокси.

2.2 Компоненты и поток данных

Сл. 14, 15

Данные проходят через несколько последовательных компонентов (рисунок 2 и таблица 7). Разделение на компоненты позволяет менять каждый из них независимо и масштабировать узкие места.

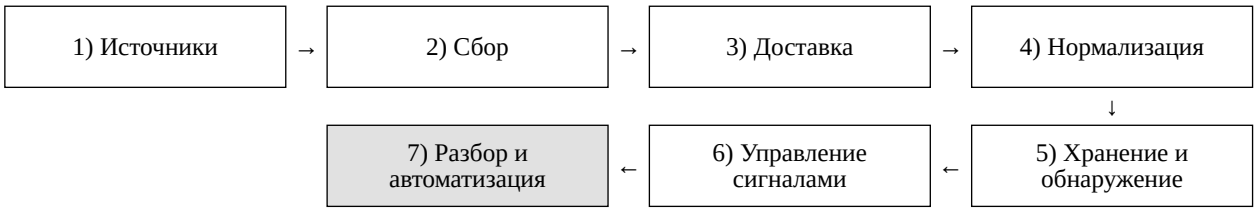


Рисунок 2 — Поток данных в системе мониторинга

Таблица 7 — Компоненты системы мониторинга

Компонент	Функция	Примеры продуктов
Сбор	Чтение журналов на источнике	Fluent Bit, Elastic Agent и Beats, auditd
Доставка	Передача в центральное хранилище с буферизацией	Kafka, Vector, Logstash
Нормализация	Приведение к единой схеме	Схемы ECS и OCSF, собственные обработчики
Хранение и обнаружение	Индексация, поиск, применение правил	Elasticsearch, OpenSearch, Wazuh, ClickHouse
Управление сигналами	Очередь, карточки, уведомления	Kibana (Elastic Security), TheHive
Автоматизация	Выполнение сценариев реагирования	Shuffle, Cortex

2.3 Пример реализации на Elastic Stack

Сл. 16

Рассмотрим, как эта схема реализуется на распространённом стеке Elastic. Его компоненты соответствуют компонентам схемы (таблица 8): Elastic Agent и Beats читают журналы на источнике, Logstash или конвейер приёма Elasticsearch обрабатывают и доставляют записи, Elasticsearch хранит события и выполняет поиск, Kibana служит интерфейсом, а её раздел Elastic Security содержит правила обнаружения, список сигналов и карточки дел [5]. Программное обеспечение Elasticsearch и Kibana распространяется по лицензиям Elastic License 2.0, SSPL 1.0 и, с августа 2024 года, AGPL 3.0 [6], поэтому перед применением нужно проверить, какая из них подходит организации.

Таблица 8 — Компоненты схемы мониторинга в Elastic Stack

Компонент схемы	В Elastic Stack	Что происходит в сквозной ситуации
Сбор	Elastic Agent, Filebeat	Читает журнал аутентификации веб-приложения
Доставка и обработка	Logstash, конвейер приёма Elasticsearch	Передаёт записи; по адресу добавляет геолокацию (обработчик geoip)

Компонент схемы	В Elastic Stack	Что происходит в сквозной ситуации
Нормализация	Схема ECS	Приводит поля к единым именам (таблица 9)
Хранение	Elasticsearch	Хранит события, по которым ищутся неудачные входы
Обнаружение	Правила Elastic Security	Подсчёт неудач и последовательность событий (глава 3)
Управление сигналами	Kibana: сигналы и дела	Аналитик первой линии видит сигнал и открывает дело

Единая схема Elastic называется ECS (Elastic Common Schema). Поля учебной схемы из таблицы 10 соответствуют ей так (таблица 9): события аутентификации в ECS отмечаются категорией `authentication`, результат — значениями `success` и `failure` [5].

Таблица 9 — Соответствие учебной схемы и ECS

Поле учебной схемы	Поле ECS	Значение в сквозной ситуации
timestamp	`@timestamp`	2026-03-12T09:00:04Z
event_type	`event.category`	`authentication`
actor.id	`user.name`	`anna`
source_ip	`source.ip`	`203.0.113.7`
outcome	`event.outcome`	`failure`

2.4 Нормализация и обогащение

Сл. 17

Источники записывают события в разных форматах, поэтому перед применением правил события приводят к единой схеме: открытые схемы OCSF [7] и ECS описывают классы событий и обязательные поля. Минимальный набор полей достаточен для большинства правил (таблица 10).

Таблица 10 — Минимальные поля нормализованного события

Поле	Назначение	Пример
timestamp	Время события в едином поясе	2026-03-12T09:01:15Z
event_type	Вид события	auth.login
actor.id	Кто действует	anna
source_ip	Откуда	203.0.113.7
outcome	Результат	failure
severity	Важность	low

Сл. 18

Затем событие дополняется контекстом, которого нет в журнале, — это **обогащение**. Обогащение отвечает на вопрос «насколько это важно» (таблица 11).

Таблица 11 — Виды обогащения

Вид	Откуда берётся	Пример результата
Контекст актива	Перечень активов	Адрес принадлежит рабочему серверу, критичность высокая
Расположение	База геолокации	Адрес из другой страны, не типичной для пользователя
Репутация	Данные об угрозах	Адрес известен как источник подбора паролей
Контекст учётной записи	Каталог пользователей	Учётная запись принадлежит администратору

Для сигнала о подборе пароля обогащение может показать, что учётная запись *anna* принадлежит бухгалтеру, а адрес 203.0.113.7 находится в списке адресов, замеченных в подборе. Это резко повышает важность сигнала.

2.5 Данные об угрозах

Сл. 19

Сведения об атаках и нарушителях поступают из внешних источников и делятся по назначению (таблица 12).

Таблица 12 — Уровни данных об угрозах

Уровень	Содержание	Потребитель
Стратегический	Мотивация нарушителей, тенденции	Руководство
Тактический	Приёмы и кампании нарушителей	Инженеры по обнаружению
Оперативный	Сведения о текущих кампаниях	Группа реагирования
Технический	Индикаторы: адреса, домены, хеши	Системы обнаружения и защиты

Для обмена такими сведениями между организациями применяются два стандарта OASIS: STIX — язык и формат описания сведений об угрозах в виде объектов и связей [8], и TAXII — протокол обмена этими объектами по HTTPS [9]. Источниками служат открытые каталоги индикаторов, коммерческие поставщики, национальные центры реагирования и отраслевые центры обмена, а также собственные инциденты организации.

3 Правила обнаружения

3.1 Язык правил Sigma

Сл. 21

Правила обнаружения удобно описывать на общем языке, не привязанном к конкретному продукту. Таким языком служит открытый стандарт **Sigma**: правило записывается в формате YAML и затем преобразуется в запрос конкретной системы [10]. Правило состоит из полей (таблица 13).

Таблица 13 — Основные поля правила Sigma

Поле	Назначение
title	Название правила
logsource	К каким журналам применяется
detection	Условие отбора событий: выбор по полям и логика
level	Важность сигнала
falsepositives	Когда правило срабатывает на нормальное поведение
tags	Привязка к тактикам и приёмам ATT&CK [11]

Разберём правила на сквозной ситуации, прослеживая причинно-следственную связь: какая запись журнала приводит к срабатыванию какой строки правила и что получается в итоге. В журнале пять записей `auth.login` с результатом `failure` для *anna* с 09:00:04 по 09:02:10 и одна запись с результатом `success` в 09:03:12.

Пример 1. Подбор пароля. Сначала базовое правило выбирает из журнала нужные события:

```
title: Неудачный вход
name: failed_login
logsource: {product: web-app, service: auth}
detection:
    selection: {event_type: auth.login, outcome: failure}
    condition: selection
```

Каждая строка правила что-то означает, и в ситуации этому соответствует конкретный результат (таблица 14).

Таблица 14 — Строки базового правила и их результат

Строка	Что означает	Что происходит в ситуации
name	Имя, по которому на правило ссылаются другие правила	Правила ниже будут считать события «неудачный вход»
logsource	В каких журналах искать	Журнал аутентификации веб-приложения, где записаны попытки входа
selection	Условие отбора: все перечисленные поля должны совпасть	Пять записей 09:00:04–09:02:10 подходят; запись 09:03:12 имеет `outcome: success` и не отбирается
condition	Когда правило срабатывает	На каждую подошедшую запись: пять неудачных входов

Подсчёт и последовательность описываются **корреляционными правилами**, которые ссылаются на базовые. Следующее правило срабатывает, если одна учётная запись получает пять и более неудач за десять минут:

```
title: Подбор пароля к учётной записи
name: failed_login_burst
correlation:
    type: event_count
    rules: [failed_login]
    group-by: [actor.id]
    timespan: 10m
    condition: {gte: 5}
```

Таблица 15 — Строки корреляционного правила и их результат

Строка	Что означает	Что происходит в ситуации
type: event_count	Считать число событий	Нужно число неудач, а не сам факт одной ошибки
rules	Какие события считать: отобранные базовым правилом	Считаются пять неудач; успешный вход не учитывается
group-by	Считать отдельно по каждому значению поля	Неудачи *anna* не смешиваются с ошибками других пользователей
timespan	Длина окна подсчёта	Пять неудач за 2 минуты 6 секунд укладываются в 10 минут
condition	Порог срабатывания	Пять не меньше пяти: сигнал формируется в 09:02:10, при пятой неудаче

Цепочка в целом такова: запись журнала → базовое правило отбирает неудачу → корреляция считает неудачи одной учётной записи → порог достигнут → сигнал «подбор пароля».

Сл. 22

Пример 2. Вход после серии неудач. Сигнал о подборе не говорит, удалось ли нарушителю войти. Это выясняет второе корреляционное правило,

которое ссылается на сигнал подбора (его имя `failed_login_burst`) и на новое базовое правило, отбирающее успешные входы:

```
title: Успешный вход
name: successful_login
logsource: {product: web-app, service: auth}
detection:
    selection: {event_type: auth.login, outcome: success}
    condition: selection
```

```
title: Успешный вход после серии неудач
correlation:
    type: temporal_ordered
    rules: [failed_login_burst, successful_login]
    group-by: [actor.id]
    timespan: 15m
```

Таблица 16 — Строки правила последовательности и их результат

Строка	Что означает	Что происходит в ситуации
type: temporal_ordered	События должны идти в заданном порядке	Сначала подбор, потом вход; вход до неудач сигнала не даст
rules	Перечень в нужном порядке	Подбор зафиксирован в 09:02:10, успешный вход — в 09:03:12
group-by	Оба события относятся к одному значению поля	И подбор, и вход выполнены под *anna*; успешный вход другого пользователя не подойдёт
timespan	Окно, в которое укладывается вся цепочка	От начала подбора до входа прошло около трёх минут — в пределах 15

Итог: шесть записей журнала превращаются в один сигнал «успешный вход после серии неудач», который и получает аналитик первой линии. Так видно, какая запись и какая строка правила привели к срабатыванию.

Сл. 23

Те же правила можно задать в Elastic Security (таблица 17). Подсчёт событий в нём выполняет правило типа «порог» (threshold): задаются поле группировки и минимальное число событий, а окно определяется расписанием правила. Для проверки числа различных значений поля к нему добавляется ограничение по числу уникальных значений [12]. Последовательность событий задаётся запросом на языке EQL, в котором для сквозной ситуации пять неудач, за которыми следует успешный вход, записываются так [13]:

```
sequence by user.name with maxspan=15m
  [ authentication where event.outcome == "failure" ] with runs=5
  [ authentication where event.outcome == "success" ]
```

Таблица 17 — Типы правил Sigma и их аналоги в Elastic Security

Sigma	Elastic Security	Параметры в сквозной ситуации
event_count	Правило «порог»	Группировка по `user.name`, порог 5 событий
value_count	Правило «порог» с ограничением по числу значений	Группировка по `source.ip`, не менее 8 различных `user.name`
temporal_ordered	Правило корреляции событий (EQL)	`sequence by user.name with maxspan=15m`

Сл. 24

Основные типы корреляции собраны в таблице 18.

Таблица 18 — Типы корреляционных правил Sigma

Тип	Что проверяет	Пример
event_count	Число событий за период	Пять неудачных входов за 10 минут
value_count	Число различных значений поля за период	Один адрес пытается войти под восемью разными учётными записями
temporal	Все перечисленные события за период в любом порядке	Вход и смена прав доступа за 15 минут
temporal_ordered	События в заданном порядке	Серия неудач, затем успешный вход

3.2 Окна времени

Сл. 25

Корреляционное правило считает события в окне времени. Окна бывают двух основных видов: неперекрывающиеся (одно окно сменяет другое) и скользящие (окно сдвигается на малый шаг). Различие существенно, если атака приходится на границу окон. На рисунке 3 четыре неудачных входа идут в минуты 3, 4, 5 и 6, порог срабатывания — три события за пять минут. Неперекрывающиеся окна 0–5 и 5–10 насчитывают по два события, и сигнала нет; скользящее окно, закончившееся в минуту 6, содержит четыре события, и сигнал формируется.

Минута	0	1	2	3	4	5	6	7	8	9
Событие				●	●	●	●			
Неперекрывающиеся окна	окно 0–5: 2 события					окно 5–10: 2 события				
Скользящее окно		окно 1–6 (шаг 1 минута): 4 события								

Рисунок 3 — Граница окон: неперекрывающиеся окна пропускают атаку, скользящее находит

Поэтому для обнаружения пороговых атак применяют скользящие окна, а неперекрывающиеся оставляют для отчётов и подсчёта метрик.

3.3 Алгоритм создания правила

Сл. 26

Правило создают в восемь шагов (рисунок 4): определить, какую атаку обнаруживаем; выяснить, какие события она оставляет; выбрать журнал; записать условие отбора; задать подсчёт и окно; назначить важность; описать возможные ложные срабатывания; проверить на данных и измерить точность.

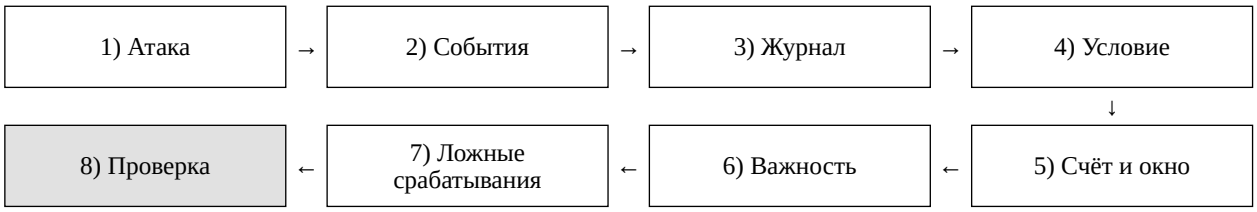


Рисунок 4 — Восемь шагов создания правила

3.4 Сложение слабых сигналов

Сл. 27

Отдельные слабые сигналы можно не доводить до аналитика, но их сочетание значимо. Каждому слабому сигналу присваивают баллы, и когда сумма баллов для одной учётной записи за период превышает порог, формируется один сильный сигнал (таблица 19).

Таблица 19 — Баллы слабых сигналов

Слабый сигнал	Баллы	Приём ATT&CK
Более трёх неудачных входов	2	T1110
Вход из новой страны	2	T1078
Успешный вход после неудач	3	T1110
Обращение к административному интерфейсу	1	T1078
Выгрузка более 1000 записей	3	T1041

Если сумма баллов за 30 минут для одной учётной записи не меньше восьми, формируется сигнал высокой важности «вероятный захват учётной записи». Аналитик получает одно уведомление с контекстом вместо пяти разрозненных.

4 Качество сигналов и ложные срабатывания

4.1 Ошибки обнаружения

Сл. 29

Каждый сигнал при проверке оказывается верным или ложным, а каждая пропущенная атака — упущением. Различают четыре исхода (таблица 20): TP (верное срабатывание: сигнал и атака), FP (ложное срабатывание: сигнал без атаки), FN (пропуск: атака без сигнала) и TN (верное молчание: нет ни атаки, ни сигнала). Ложным срабатыванием называется ошибочная классификация безвредной активности как вредоносной [14].

Таблица 20 — Исходы работы правила

	Атака была	**Атаки не было**
Сигнал есть	TP	FP
Сигнала нет	FN	TN

Сл. 30, 31

Качество правила описывают двумя числами. **Точность** (Precision) — доля верных сигналов среди всех: Precision = TP / (TP + FP). **Полнота** (Recall) — доля найденных атак среди всех: Recall = TP / (TP + FN). Они тянут в разные стороны: порог строже — меньше ложных, но больше пропусков.

Пример: правило выдало 40 сигналов, из них 30 верных, при этом всего за период было 50 атак. Тогда Precision = 30 / 40 = 0,75, а Recall = 30 / 50 = 0,6. Если повысить порог, точность вырастет, а полнота упадёт.

4.2 Перегрузка аналитика потоком сигналов

Сл. 32

Если сигналов много, а большинство ложные, внимание аналитика притупляется, и он начинает пропускать настоящие. Типичные причины сведены в таблицу 21.

Таблица 21 — Причины большого числа ложных срабатываний

Причина	**Что происходит**
Слишком общие правила	Срабатывают на обычное поведение
Нет контекста	Неясно, критичен ли актив
Нет описания нормальной работы	Любое отклонение считается подозрительным
Дублирующие правила	Одна атака даёт много однотипных сигналов

4.3 Способы снижения ложных срабатываний

Сл. 33

Основные способы показаны в таблице 22. Любое подавление должно быть временным и иметь ответственного, иначе в подавленном окажется настоящая атака.

Таблица 22 — Способы снижения ложных срабатываний

Способ	Суть	Пример
Настройка	Поднять порог, добавить исключения	Порог 5 неудач → 10
Обогащение	Учесть контекст актива и репутацию	Для рабочих серверов — выше важность
Корреляция	Объединить слабые сигналы	Баллы за несколько признаков
Подавление	Временно не сигналить о заведомо безопасном	Известный сканер уязвимостей, с датой пересмотра
Уровни уведомления	Малозначимое только в панель	Информационные сигналы без уведомлений

Сл. 34

Например, правило «пять неудач за пять минут» даёт ежедневно десятки ложных срабатываний из-за общего адреса офиса, откуда много сотрудников ошибаются при входе. Решение: исключить адреса корпоративных шлюзов или считать неудачи по паре «адрес и учётная запись».

4.4 Обнаружение как код

Сл. 35

Правила хранят и обслуживают как программный код: в системе контроля версий, с рецензированием изменений, автоматической проверкой формата и тестами на подготовленных данных, с метриками точности и полноты по каждому правилу. Для описания каждого правила применяют шаблон, например Alerting and Detection Strategy компании Palantir, который требует для правила указать цель, данные, логику, возможные ложные срабатывания, способ проверки и порядок реагирования [15].

5 Реагирование и его автоматизация

5.1 Жизненный цикл реагирования

Сл. 37

Современное международное руководство NIST SP 800-61 Rev. 3 описывает реагирование как часть управления киберрисками и опирается на функции фреймворка NIST CSF 2.0 [4,16]. Для центра мониторинга важны три функции: обнаружение (поиск и анализ событий), реагирование (управление инцидентом, анализ, локализация, устранение, отчётность) и восстановление; результаты каждого случая возвращаются в подготовку и улучшение правил (рисунок 5).

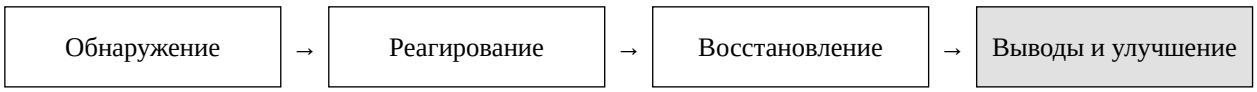


Рисунок 5 — Цикл реагирования

В сквозной ситуации реагирование — это блокировка сеанса, смена пароля и проверка действий нарушителя; выводом становится настройка правила.

5.2 Автоматизация реагирования

Сл. 38

Рутинные действия выполняют платформы автоматизации (SOAR): они объединяют инструменты центра и исполняют сценарии реагирования. Типовые автоматизации перечислены в таблице 23.

Таблица 23 — Типовые автоматизации

Условие	Автоматическое действие	Риск действия
Подбор пароля с внешнего адреса	Заблокировать адрес на межсетевом экране	Низкий
Успешный вход после подбора	Заблокировать учётную запись, создать карточку инцидента	Средний

Автоматические действия градуируют по риску: низкорисковые (блокировка адреса) выполняются сразу, среднерисковые (блокировка учётной записи) — с уведомлением и возможностью отмены, высокорисковые (изоляция узла, отключение сервиса) — только с одобрения человека.

Сл. 39

Сценарий для сквозной ситуации: заблокировать внешний адрес; после успешного входа заблокировать учётную запись и создать карточку инцидента.

ЗАКЛЮЧЕНИЕ

Сл. 40

Основные положения лекции собраны в таблице 24.

Таблица 24 — Основные положения лекции

Глава	Главное
1. Роли и процессы	Три уровня аналитиков; сигнал разбирается по трём решениям; регламент разбора; показатели работы центра
2. Архитектура	Мониторинг на нескольких уровнях; сбор, доставка, нормализация, обогащение, хранение, управление сигналами
3. Правила	Sigma: базовые и корреляционные правила; скользящие окна; сложение слабых сигналов
4. Качество	TP, FP, FN, TN; Precision и Recall; перегрузка аналитика сигналами; обнаружение как код
5. Реагирование	Цикл по NIST SP 800-61 Rev. 3; автоматизация с градацией по риску

На практическом занятии 2 по подготовленным журналам разрабатываются 6–8 правил обнаружения, они применяются скриптом с агрегацией по окнам времени, составляется отчёт о срабатываниях и предлагаются меры по снижению ложных срабатываний.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. National Institute of Standards and Technology. Risk Management Framework for Information Systems and Organizations: technical report SP 800-37 Rev. 2. 2018.
2. NIST Computer Security Resource Center. Glossary: alert (по CNSSI 4009) [Электронный ресурс]. URL: https://csrc.nist.gov/glossary/term/alert.
3. National Institute of Standards and Technology. Security and Privacy Controls for Information Systems and Organizations: technical report SP 800-53 Rev. 5. 2020.
4. National Institute of Standards and Technology. Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile: technical report SP 800-61 Rev. 3. 2025.
5. Elastic. Elastic Security ECS field reference [Электронный ресурс]. URL: https://www.elastic.co/docs/reference/security/fields-and-object-schemas/siem-field-reference.
6. Elastic. Elastic announces open source license for Elasticsearch and Kibana source code [Электронный ресурс]. 2024. URL: https://www.businesswire.com/news/home/20240829537786/en.
7. OCSF. Open Cybersecurity Schema Framework [Электронный ресурс]. URL: https://schema.ocsf.io/.
8. OASIS. STIX Version 2.1 [Электронный ресурс]. 2021. URL: https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html.
9. OASIS. TAXII Version 2.1 [Электронный ресурс]. 2021. URL: https://docs.oasis-open.org/cti/taxii/v2.1/taxii-v2.1.html.
10. SigmaHQ. Sigma Rules Specification [Электронный ресурс]. URL: https://sigmahq.io/sigma-specification/.
11. MITRE. MITRE ATT&CK [Электронный ресурс]. URL: https://attack.mitre.org/.

12. Elastic. Threshold rules. Elastic Security documentation [Электронный ресурс]. URL: https://www.elastic.co/docs/solutions/security/detect-and-alert/threshold.

13. Elastic. EQL syntax reference [Электронный ресурс]. URL: https://www.elastic.co/docs/reference/query-languages/eql/eql-syntax.

14. Kent K. и др. Guide to Integrating Forensic Techniques into Incident Response: technical report SP 800–86. 2006.

15. Palantir. Alerting and Detection Strategy Framework [Электронный ресурс]. URL: https://github.com/palantir/alerting-detection-strategy-framework.

16. National Institute of Standards and Technology. The NIST Cybersecurity Framework (CSF) 2.0: technical report CSWP 29. 2024.

ПРИЛОЖЕНИЕ А

Вопросы для самопроверки

Каждый вопрос сопровождается кратким ответом, составленным по материалу лекции.

1. Чем событие отличается от сигнала и от инцидента?

Ответ. Событие — любое наблюдаемое явление в системе или сети (запись о неудачном входе). Сигнал — уведомление, которое формирует правило обнаружения при подозрительной комбинации событий. Инцидент — подтверждённое происшествие, ставящее под угрозу конфиденциальность, целостность или доступность. Событий много, сигналов мало, инцидентов ещё меньше.

2. Какие три решения может принять аналитик первой линии при разборе сигнала?

Ответ. Подтвердить угрозу и передать на расследование; признать срабатывание ложным и настроить правило; запросить данные и разобрать повторно после обогащения.

3. Почему мониторинг ведут на нескольких уровнях?

Ответ. Каждый уровень видит свою часть: сетевой не видит содержимого шифрованного обмена, хостовый не видит соседние узлы, журналы приложения не показывают атак, не дошедших до него. Совместный просмотр уровней даёт полную картину.

4. Зачем нужны нормализация и обогащение?

Ответ. Нормализация приводит события из разных источников к единой схеме, поэтому одно правило работает для всех. Обогащение добавляет контекст (важность актива, расположение, репутацию), который определяет приоритет сигнала.

5. Почему неперекрывающиеся окна могут пропустить атаку?

Ответ. Если серия событий приходится на границу двух окон, в каждом окне событий меньше порога, и сигнала нет. Скользящее окно, сдвигающееся на малый шаг, захватывает всю серию.

6. Как рассчитать точность и полноту правила? Что произойдёт при повышении порога?

Ответ. Precision = TP / (TP + FP), Recall = TP / (TP + FN). При повышении порога сигналов становится меньше, ложных тоже, поэтому точность растёт, но часть атак не достигает порога, поэтому полнота падает.

7. Назовите три способа снижения ложных срабатываний.

Ответ. Настройка порога и исключений; обогащение контекстом; сложение слабых сигналов по баллам. Подавление применимо только временно и с ответственным.

8. Почему автоматические действия градуируют по риску?

Ответ. Ошибочная блокировка адреса почти не вредит, а ошибочная изоляция узла или отключение сервиса нарушает работу организации. Поэтому действия с высоким риском выполняются только после одобрения человека.